OWASP WebGoat e WebWolf

Laboratório de Segurança em Aplicações Web

Giuliano Marcus Bianco
Luis Renato Freitas de Almeida
Nicolas Arthur Raulino Oliveira

Instituto Federal de Santa Catarina

Novembro de 2025

Introdução

Contextualização

- O crescimento das aplicações web trouxe novos desafios de segurança.
- A OWASP promove boas práticas e ferramentas para mitigar vulnerabilidades.
- WebGoat e WebWolf são plataformas didáticas para aprendizado prático de segurança.

A OWASP

O que é a OWASP

- Comunidade global dedicada à segurança de software.
- Produz guias, ferramentas e projetos abertos, como o **OWASP Top 10**.
- O objetivo é ajudar desenvolvedores a criar aplicações mais seguras.

OWASP WebGoat

O que é o WebGoat

- Aplicação web vulnerável criada intencionalmente.
- Desenvolvida em Java e executada no servidor Apache Tomcat.
- Usada para ensinar como explorar e corrigir falhas de segurança.

Exemplos de vulnerabilidades abordadas

- Injeção de SQL (*SQL Injection*);
- Quebra de autenticação e controle de sessão;
- Cross-Site Scripting (XSS);
- Exposição de dados sensíveis;
- Controle de acesso incorreto.

OWASP WebWolf

O que é o WebWolf

- Ferramenta complementar ao WebGoat.
- Simula o ambiente de um atacante externo.
- Permite receber e-mails falsos, capturar dados e testar exploits.

Integração com o WebGoat

- WebGoat envia dados ao WebWolf durante atividades práticas.
- Juntos, simulam cenários reais de ataque e defesa.
- Ideal para treinamento ético em segurança web.

Demonstração

Ambiente de Teste

- Instalação via Docker Compose com dois containers: `webgoat` e `webwolf`.
- Endereços padrão:
  - WebGoat: `http://localhost:8080/WebGoat`
  - WebWolf: `http://localhost:9090/WebWolf`
- Aulas interativas e relatórios automáticos.

Exemplo de Exercício

- Exploração de um formulário vulnerável (ex: login).
- Observação dos logs e e-mails capturados no WebWolf.
- Discussão sobre a mitigação da falha.

Conclusão

Considerações Finais

- WebGoat e WebWolf permitem aprendizado prático e seguro de vulnerabilidades.
- Ajudam a compreender como proteger aplicações contra ataques reais.
- São ferramentas essenciais para o ensino de segurança da informação.

Referências I

ANDERSON, Ross J. **Security Engineering: A Guide to Building Dependable Distributed Systems**. 3. ed. Hoboken: Wiley, 2020. ISBN 978-1-119-64278-7.

FOUNDATION, OWASP. **OWASP Top 10 – The Ten Most Critical Web Application Security Risks**. 2021. Acesso em: 12 nov. 2025. Disponível em: https://owasp.org/Top10/.

FOUNDATION, OWASP. **OWASP WebGoat: A deliberately insecure web application maintained by OWASP for educational purposes**. 2025. Acesso em: 12 nov. 2025. Disponível em: https://owasp.org/www-project-webgoat/.

FOUNDATION, OWASP. **OWASP WebWolf: Companion application for WebGoat to simulate attacker environment**. 2025. Acesso em: 12 nov. 2025. Disponível em: https://owasp.org/www-project-webgoat/.

Referências II

FOUNDATION, OWASP. **The Open Web Application Security Project (OWASP)**. 2025. Acesso em: 12 nov. 2025. Disponível em: https://owasp.org.

STALLINGS, William. **Cryptography and Network Security: Principles and Practice**. 8. ed. Boston: Pearson Education, 2020. ISBN 978-0-13-444428-4.